TECHNICAL AUDIT & ARCHITECTURE SPECIFICATION

GYM Management System (PHP & MySQL)

Document Classification: Comprehensive System Specification & Technical Audit
Target Audience: Software Architects, Security Auditors, AI Engineers & Developers
Current Operating State: ONLINE & FULLY FUNCTIONAL
Local Development Server: `http://127.0.0.1:8080/` (PHP 8.4.1 CLI Server)
Database: MySQL 9.3.0 (`gymdb` schema populated)
Document Generated: November 2026

---

1. Executive Summary & Project Identification

The **GYM Management System** is a full-featured web application designed for gym operators, personal fitness clubs, and members. It features a dual-portal architecture: 1. **Public & Member Portal**: Allows prospective members to explore tiered fitness packages, register accounts, sign in, book packages, manage profiles, update passwords, and inspect itemized booking receipts with complete payment history ledgers. 2. **Staff & Administrator Portal**: Restricted console providing real-time KPI metrics in an iOS Control Center dashboard, category management, sub-package classification, membership package creation/editing, booking management partitioned by payment state, and date-filtered reporting engines.

The application has been completely upgraded from legacy Bootstrap styling into an ultra-modern, Apple-inspired **iOS Glassmorphism Design System** featuring dynamic ambient mesh gradients, 28px continuous squircle curvature, multi-layer specular highlights, and fluid 60fps spring transitions.

---

2. Technology Stack & Runtime Environment

2.1 Backend Layer

- **Language**: PHP (tested on PHP 8.4.1; compatible with PHP 7.4 through 8.4+).
- **Architecture**: Procedural multi-page application (Script-per-page pattern) with centralized database configuration.
- **Database Abstraction**: PHP Data Objects (PDO) with prepared statements (`PDO::ATTR_ERRMODE` , UTF-8 charset).

- **Session Management**: Native PHP server sessions (`$_SESSION['uid']` , `$_SESSION['adminid']` , `$_SESSION['email']` , `$_SESSION['name']`).

2.2 Database Layer

- **RDBMS**: MySQL 9.3.0 (also MariaDB compatible).
- **Database Name**: `gymdb` .
- **Character Set**: `utf8mb4` / `utf8mb4_general_ci` .
- **Storage Engine**: InnoDB with relational foreign key references.

2.3 Frontend & UI Layer

- **Design System**: Custom iOS Glassmorphism Engine (`gym/css/ios-glass.css` , `gym/admin/css/ios-admin-glass.css`).
- **CSS Architecture**: CSS Custom Properties (CSS variables), `backdrop-filter: blur(28px) saturate(190%)` , responsive Flexbox & CSS Grid.
- **Base Grid & Utilities**: Bootstrap 4.x responsive layout grid.
- **Typography**: Apple SF Pro / Plus Jakarta Sans / Inter font stack.
- **Iconography**: FontAwesome 4.7.0 vector icons.
- **Client Scripting**: Vanilla JavaScript (ES6+), jQuery 3.2.1, Bootstrap JS, Pace.js, DataTables.

---

3. Directory & File-by-File Taxonomy

```
GYM-Management-System-using-PHP/
├── PROJECT_AUDIT_AND_ARCHITECTURE_SPEC.md   # This comprehensive technical audit
├── PROJECT_AUDIT_AND_ARCHITECTURE_SPEC.pdf  # Compiled printable PDF audit specification
├── PROJECT_AUDIT_AND_ARCHITECTURE_SPEC.txt  # Plain-text audit specification
├── Readme.txt                               # Original deployment instructions
├── SQL File/
│   └── gymdb.sql                            # Relational schema DDL & initial seed records
└── gym/                                     # Web application document root
    ├── index.php                            # Public homepage, hero & pricing plan cards
    ├── login.php                            # Member authentication portal
    ├── registration.php                     # Member onboarding & registration form
    ├── about.php                            # Gym mission, facility features, coaching pillars
    ├── contact.php                          # Contact channels, support email & phone
    ├── Booking-History.php                  # Member subscription timeline & receipt links
    ├── booking-details.php                  # Itemized booking receipt & transaction ledger
    ├── profile.php                          # Member personal settings & profile editor
    ├── changepassword.php                   # Member password update portal
    ├── logout.php                           # Member session destruction & redirect
    ├── include/
    │   ├── config.php                       # Database PDO credentials & connection setup
    │   ├── header.php                       # Floating glass pill navbar & ambient canvas
    │   ├── footer.php                       # Minimalist frosted glass footer
    │   └── sidebar.php                      # Legacy sidebar component
    ├── css/
    │   ├── ios-glass.css                    # Master iOS Glassmorphism design system
    │   ├── bootstrap.min.css                # Base grid system
    │   ├── font-awesome.min.css             # Vector icon suite
    │   ├── animate.css                      # Keyframe animations
    │   └── style.css                        # Legacy stylesheet
    ├── js/                                  # JavaScript plugins (jQuery, Bootstrap, etc.)
    └── admin/                               # Staff & administrative management portal
        ├── index.php                        # Control Center dashboard & KPI metric widgets
        ├── login.php                        # Admin authentication console
        ├── logout.php                       # Admin session termination
        ├── add-category.php                 # Category creation & listing table
        ├── add-package.php                  # Package type definition & list
        ├── add-post.php                     # Membership plan creation form
        ├── manage-post.php                  # Membership plan editor & table
        ├── edit-post.php                    # Membership plan update handler
        ├── booking-history.php              # Comprehensive booking ledger
        ├── new-bookings.php                 # Filtered: Unpaid / New bookings
        ├── partial-payment-bookings.php     # Filtered: Partial payment bookings
        ├── full-payment-bookings.php        # Filtered: Fully paid bookings
        ├── booking-history-details.php      # Booking action sheet & payment processing modal
        ├── report-booking.php               # Date-filtered booking report generator
        ├── report-registration.php          # Date-filtered user registration report
        ├── profile.php                      # Admin profile management
        ├── change-password.php              # Admin password change
        ├── ajaxfile.php                     # Asynchronous category-to-package AJAX loader
        ├── css/
        │   ├── ios-admin-glass.css          # iOS Glassmorphism overrides for Admin
        │   └── main.css                     # Vali admin base layout
        └── include/
            ├── config.php                   # Admin database connection module
```

```
├── header.php                  # Frosted topbar & profile dropdown
└── sidebar.php                 # Translucent sidebar dock with route badges
```

---

4. Complete Relational Database Schema

The database `gymdb` contains 7 relational tables:

4.1 Table: `tbladmin`

Manages administrative staff accounts. | Column | Type | Nullable | Key | Default | Description | | :--- | :--- | :--- | :--- | :--- | :--- | | `id` | `INT(11)` | NO | PRIMARY (Auto Inc) | None | Unique admin record ID | | `name` | `VARCHAR(45)` | YES | | NULL | Full name of administrator | | `email` | `VARCHAR(45)` | YES | | NULL | Login username / email | | `mobile` | `VARCHAR(45)` | YES | | NULL | Contact mobile number | | `password` | `VARCHAR(100)` | YES | | NULL | MD5 password hash | | `create_date` | `TIMESTAMP` | YES | | `current_timestamp()` | Registration timestamp |

Default Seed Credential: `admin@gmail.com` / `Test@12345` (`5c428d8875d2948607f3e3fe134d71b4`)

4.2 Table: `tbluser`

Stores member registrations, contact records, and credentials. | Column | Type | Nullable | Key | Default | Description | | :--- | :--- | :--- | :--- | :--- | :--- | | `id` | `INT(11)` | NO | PRIMARY (Auto Inc) | None | Unique customer ID | | `fname` | `VARCHAR(45)` | YES | | NULL | Customer first name | | `lname` | `VARCHAR(45)` | YES | | NULL | Customer last name | | `email` | `VARCHAR(45)` | YES | | NULL | Unique email address | | `mobile` | `VARCHAR(45)` | YES | | NULL | Contact mobile number | | `password` | `VARCHAR(100)` | YES | | NULL | MD5 password hash | | `state` | `VARCHAR(45)` | YES | | NULL | State or province | | `city` | `VARCHAR(45)` | YES | | NULL | City of residence | | `address` | `VARCHAR(200)` | YES | | NULL | Full residential address | | `create_date` | `TIMESTAMP` | YES | | `current_timestamp()` | Account creation date |

Default Seed Credential: `john@test.com` / `Test@123` (`f925916e2754e5e03f75dd58a5733251`)

4.3 Table: `tblcategory`

Workout categories (e.g., Strength, Yoga, Cardio, CrossFit). | Column | Type | Nullable | Key | Default | Description | | :--- | :--- | :--- | :--- | :--- | :--- | | `id` | `INT(11)` | NO | PRIMARY (Auto Inc) | None | Unique category ID | | `category_name` | `VARCHAR(45)` | YES | | NULL | Category display label | | `status` | `VARCHAR(45)` | YES | | `'0'` | Active (`0`) / inactive status |

4.4 Table: `tblpackage`

Sub-package classifications mapped to categories. | Column | Type | Nullable | Key | Default | Description | | :--- | :--- | :--- | :--- | :--- | :--- | | `id` | `INT(11)` | NO | PRIMARY (Auto Inc) | None | Unique package type ID | | `cate_id` | `VARCHAR(45)` | YES | FK -> `tblcategory.id` | NULL | Parent category foreign ID | | `PackageName` | `VARCHAR(45)` | YES | | NULL | Name of package type |

4.5 Table: `tbladdpackage`

The published gym membership plans shown on the public pricing page. | Column | Type | Nullable | Key | Default | Description | | :--- | :--- | :--- | :--- | :--- | :--- | | `id` | `INT(11)` | NO | PRIMARY (Auto Inc) | None | Unique plan ID | | `category` | `VARCHAR(45)` | YES | FK -> `tblcategory.id` | NULL | Workout category ID | | `titlename` | `VARCHAR(450)` | YES | | NULL | Membership plan title | | `PackageType` | `VARCHAR(45)` | YES | FK -> `tblpackage.id` | NULL | Sub-package type ID | | `PackageDuratiobn` | `VARCHAR(45)` | YES | | NULL | Duration (e.g. "3 Month", "6 Month") | | `Price` | `VARCHAR(45)` | YES | | NULL | Price in USD (e.g. "800") | | `uploadphoto` | `VARCHAR(450)` | YES | | NULL | Plan banner image path | | `Description` | `VARCHAR(450)` | YES | | NULL | Features & perk description | | `create_date` | `TIMESTAMP` | YES | | `current_timestamp()` | Plan creation date |

4.6 Table: `tblbooking`

Tracks member package bookings. | Column | Type | Nullable | Key | Default | Description | | :--- | :--- | :--- | :--- | :--- | :--- | | `id` | `INT(11)` | NO | PRIMARY (Auto Inc) | None | Unique booking ID | | `package_id` | `VARCHAR(45)` | YES | FK -> `tbladdpackage.id` | NULL | Selected package ID | | `userid` | `VARCHAR(45)` | YES | FK -> `tbluser.id` | NULL | Member customer ID | | `booking_date` | `TIMESTAMP` | YES | | `current_timestamp()` | Date booking occurred | | `payment` | `VARCHAR(45)` | YES | | NULL | Cumulative amount paid | | `paymentType` | `VARCHAR(45)` | YES | | NULL | Status: NULL, "Partial Payment", "Full Payment" |

4.7 Table: `tblpayment`

Individual transaction ledger entries linked to bookings. | Column | Type | Nullable | Key | Default | Description | | :--- | :--- | :--- | :--- | :--- | :--- | | `id` | `INT(11)` | NO | PRIMARY (Auto Inc) | None | Unique transaction ID | | `bookingID` | `VARCHAR(45)` | YES | FK -> `tblbooking.id` | NULL | Associated booking reference | | `paymentType` | `VARCHAR(45)` | YES | | NULL | Transaction type: "Partial Payment" / "Full Payment" | | `payment` | `VARCHAR(45)` | YES | | NULL | Installment amount paid | | `payment_date` | `TIMESTAMP` | YES | | `current_timestamp()` | Transaction timestamp |

---

5. UI Architecture & Design System (iOS Glassmorphism)

5.1 Design Tokens (`gym/css/ios-glass.css`)

- **Background**: Deep midnight slate `#07090e` under living ambient light mesh (`.ambient-glow`).
- **Orb Gradients**:
- Orb 1 (Cyan/Blue): `radial-gradient(circle, #38bdf8 0%, rgba(56,189,248,0) 70%)`
- Orb 2 (Violet): `radial-gradient(circle, #8b5cf6 0%, rgba(139,92,246,0) 70%)`
- Orb 3 (Sunset Coral): `radial-gradient(circle, #f97316 0%, rgba(249,115,22,0) 70%)`
- **Glass Specular Physics**:
- `background: rgba(255, 255, 255, 0.06);`
- `backdrop-filter: blur(28px) saturate(190%);`
- `border: 1px solid rgba(255, 255, 255, 0.13);`
- `box-shadow: 0 24px 48px -12px rgba(0, 0, 0, 0.55), inset 0 1px 1px 0 rgba(255, 255, 255, 0.25);`
- **Curves & Radii**:
- Large Cards & Modals: Continuous squircle `border-radius: 24px` to `28px`
- Pill Bars & Buttons: `border-radius: 40px` (capsules) / `14px` (form elements)
- **Spring Curves**:
- Native iOS Spring: `cubic-bezier(0.25, 1, 0.5, 1)`
- Bouncy Action: `cubic-bezier(0.34, 1.56, 0.64, 1)`
- Active Press: `transform: scale(0.97)` on `:active`

---

6. End-to-End Functional Flows

Flow 1: Member Authentication & Session Lifecycle

```
[Unauthenticated User]
       │
       ├──> Visits index.php (Can browse pricing cards)
       │       └──> Clicks "Sign In to Book" ──> login.php
       │
       └──> Visits registration.php
               │
               ├── Validates First Name, Mobile, Email, Password match
               ├── Queries tbluser for existing email OR mobile duplicate
               └── Inserts into tbluser ──> Redirects to login.php
                       │
                       ▼
             [login.php]
             ├── Queries tbluser WHERE email=:email AND password=MD5(:password)
             ├── Sets $_SESSION['uid'] = $row['id']
             ├── Sets $_SESSION['email'] = $row['email']
             ├── Sets $_SESSION['name'] = $row['fname']
             └── Redirects to index.php (Shows active member navbar)
```

Flow 2: Membership Plan Booking Flow

```
[Authenticated Member: $_SESSION['uid'] present]
       │
       ▼
 [index.php: Plan Cards]
       │
       ├── Member reviews pricing tier ($600/3 Month, $800/6 Month, etc.)
       ├── Submits POST ['submit'] with hidden input ['pid' => plan_id]
       ├── Executes: INSERT INTO tblbooking (package_id, userid) VALUES (:pid, :uid)
       └── Alerts "Package has been booked successfully!" ──> Redirects to Booking-History.php
```

Flow 3: Booking Receipt & Payment Ledger Lifecycle

```
[Booking-History.php]
       │
       ├── Queries tblbooking JOIN tbladdpackage JOIN tbluser JOIN tblcategory JOIN tblpackage
       ├── Renders glass timeline with status chips & formatted dates
       └── Clicks "Receipt" ──> booking-details.php?bookingid=<ID>
              │
              ▼
        [booking-details.php]
        ├── Renders Apple-style membership pass with Plan Price, Duration & Category
        ├── Queries tblpayment WHERE bookingID=:bookindid
        ├── Calculates cumulative amount paid: $gpayment = SUM(payment)
        ├── Renders full transaction history ledger with timestamps
        └── Displays live payment status badge:
              ├── "Paid in Full" (paymentType == 'Full Payment')
              ├── "Partial Payment" (paymentType == 'Partial Payment')
              └── "Pending Payment" (paymentType IS NULL)
```

Flow 4: Administrator Management & Payment Processing

```
[Admin Authentication: admin/login.php]
       │
       ├── Authenticates against tbladmin WHERE email=:email AND password=MD5(:password)
       ├── Sets $_SESSION['adminid'], $_SESSION['email'], $_SESSION['name']
       └── Redirects to admin/index.php
              │
              ▼
        [admin/index.php: Control Center]
        ├── Live KPI Cards: Listed Categories, Package Types, Active Plans, Total Bookings
        ├── Status Cards: Pending Payment, Partial Payment, Fully Paid
        └── Quick Action Shortcuts (Add Plan, Add Category, Review Bookings, Reports)

[Admin Payment Collection: admin/booking-history-details.php?bookingid=<ID>]
       │
       ├── Displays customer details, selected plan price, and existing payment ledger
       ├── If paymentType != 'Full Payment' ──> "Take Action" modal button is ACTIVE
       └── Admin opens Action Sheet Modal:
             ├── Chooses Payment Type: "Partial Payment" OR "Full Payment"
             ├── If Partial: enters installment amount
             ├── If Full: calculates remaining balance: ($pricess - $gpayment)
             ├── Inserts row into tblpayment (bookingID, paymentType, payment)
             ├── Updates tblbooking SET paymentType=:Paymenttype WHERE id=:bookindid
             └── Alerts "Payment Details has been updated" ──> Refreshes ledger
```

---

7. Complete Script & API Matrix

Script Path	Purpose	Auth Required	Methods	Database Operations
`gym/index.php`	Homepage & Pricing	Optional	GET, POST	`SELECT tbladdpackage`, `INSERT tblbooking`
`gym/login.php`	Member Login	Public	GET, POST	`SELECT tbluser`
`gym/registration.php`	Member Registration	Public	GET, POST	`SELECT tbluser` (dupe check), `INSERT tbluser`
`gym/Booking-History.php`	Subscription History	Member (`uid`)	GET	`SELECT tblbooking` + 4 table joins
`gym/booking-details.php`	Receipt & Ledger	Member (`uid`)	GET	`SELECT tblbooking`, `SELECT tblpayment`
`gym/profile.php`	Personal Profile	Member (`uid`)	GET, POST	`SELECT tbluser`, `UPDATE tbluser`
`gym/changepassword.php`	Change Password	Member (`uid`)	GET, POST	`SELECT tbluser`, `UPDATE tbluser`
`gym/logout.php`	Member Logout	Member	GET	`session_destroy()`
`gym/about.php`	Facility Info	Public	GET	None
`gym/contact.php`	Support Details	Public	GET	None
`gym/admin/index.php`	Control Center	Admin (`adminid`)	GET	`SELECT count(*)` across all tables
`gym/admin/login.php`	Admin Login	Public	GET, POST	`SELECT tbladmin`
`gym/admin/logout.php`	Admin Logout	Admin	GET	`session_destroy()`
`gym/admin/add-category.php`	Category CRUD	Admin	GET, POST	`INSERT tblcategory`, `SELECT tblcategory`
`gym/admin/add-package.php`	Package Type CRUD	Admin	GET, POST	`INSERT tblpackage`, `SELECT tblpackage`
`gym/admin/add-post.php`	Create Plan	Admin	GET, POST	`SELECT tblcategory`, `INSERT tbladdpackage`
`gym/admin/manage-post.php`	List & Delete Plans	Admin	GET, POST	`SELECT tbladdpackage`, `DELETE tbladdpackage`

Script Path	Purpose	Auth Required	Methods	Database Operations
`gym/admin/edit-post.php`	Update Plan	Admin	GET, POST	`SELECT tbladdpackage`, `UPDATE tbladdpackage`
`gym/admin/booking-history.php`	All Bookings List	Admin	GET	`SELECT tblbooking` + joins
`gym/admin/new-bookings.php`	Unpaid Bookings	Admin	GET	`SELECT tblbooking WHERE paymentType IS NULL`
`gym/admin/partial-payment-bookings.php`	Partial Payments	Admin	GET	`SELECT tblbooking WHERE paymentType='Partial Payment'`
`gym/admin/full-payment-bookings.php`	Full Payments	Admin	GET	`SELECT tblbooking WHERE paymentType='Full Payment'`
`gym/admin/booking-history-details.php`	Process Payment	Admin	GET, POST	`SELECT tblbooking`, `INSERT tblpayment`, `UPDATE tblbooking`
`gym/admin/report-booking.php`	Booking Report	Admin	GET, POST	`SELECT tblbooking WHERE booking_date BETWEEN ...`
`gym/admin/report-registration.php`	User Report	Admin	GET, POST	`SELECT tbluser WHERE create_date BETWEEN ...`
`gym/admin/profile.php`	Admin Profile	Admin	GET, POST	`SELECT tbladmin`, `UPDATE tbladmin`
`gym/admin/change-password.php`	Admin Password	Admin	GET, POST	`SELECT tbladmin`, `UPDATE tbladmin`
`gym/admin/ajaxfile.php`	Dynamic Select AJAX	Admin	POST	`SELECT tblpackage WHERE cate_id=:category`

---

8. Security Audit & Technical Debt Matrix

This matrix provides the exact technical recommendations for subsequent AI agents or engineering teams:

Vulnerability / Item	Severity	Current Implementation	Risk Profile	Recommended Remediation
Password Storage	**HIGH**	`md5($password)` without salt	Rainbow table vulnerability; fast offline collision brute forcing	Migrate to standard `password_hash($pwd, PASSWORD_DEFAULT)` and `password_verify()`
CSRF Protection	**HIGH**	Forms submit directly via standard POST without tokens	Vulnerable to cross-site request forgery attacks	Implement `$_SESSION['csrf_token']` generated via `bin2hex(random_bytes(32))` and validate on every POST
Session Security	**MEDIUM**	Standard `session_start()` without cookie flags	Vulnerable to XSS session theft and session fixation	Set `session_set_cookie_params(['lifetime' => 0, 'path' => '/', 'domain' => '', 'secure' => false, 'httponly' => true, 'samesite' => 'Lax'])` and call `session_regenerate_id(true)` upon successful login
Schema Normalization	**MEDIUM**	Foreign keys and currency stored as `VARCHAR(45)`	Loss of database-level referential integrity; potential string comparison anomalies	Alter schema columns to `INT(11)` for IDs and `DECIMAL(10,2)` for `Price` and `payment`
Schema Typo	**LOW**	Column named `PackageDuratiobn` in `tbladdpackage`	Developer confusion / code typos	Rename column to `PackageDuration` or alias cleanly in queries
Global Error Handling	**LOW**	`error_reporting(0)` used uniformly	Conceals runtime exceptions during local development	Use environment variable `APP_ENV=development` to enable `E_ALL` in dev while logging errors to disk in production

---

9. Recent Bug Fixes Applied

1. **"Headers Already Sent" Whitespace Fix**:
2. `gym/login.php`, `gym/admin/login.php`, and `gym/admin/ajaxfile.php` had leading carriage returns/newlines before `<?php`.

3. This caused PHP to emit body bytes before `session_start()`, preventing `Set-Cookie` session issuance and breaking login redirects.
4. All leading whitespace was trimmed cleanly.
5. **Missing `exit()` on Header Redirects**:
6. Redirection headers (`header("location: ...")`) did not call `exit()`, allowing downstream code to execute. Added `exit()` after all headers.
7. **Admin User Object Attribute Bug**:
8. `gym/admin/login.php` assigned `$_SESSION['name'] = $row['fname']`, but `tbladmin` contains column `name` rather than `fname`. Updated to `$row['name']`.
9. **Session Parenthesis Syntax Bug**:
10. Corrected instances of `if (strlen($_SESSION['adminid']==0))` to `if (empty($_SESSION['adminid']))`.

---

10. Master Prompt for Subsequent AI / Developers

Use the prompt below when handing off this codebase to another AI assistant to execute adjustments:

```
You are an expert full-stack PHP/MySQL engineer and security architect.
You are tasked with making refinements to the GYM Management System.

Project Context:
- Document Root: gym/
- Backend: PHP 8.4 with PDO prepared statements
- Database: MySQL (gymdb) with tables tbluser, tbladmin, tblbooking, tblpayment, tbladdpackage, tblc
- UI System: Custom iOS Glassmorphism (css/ios-glass.css and admin/css/ios-admin-glass.css)
- Running local instance: http://127.0.0.1:8080/

Rules to Maintain:
1. Preserve all existing database connections ($dbh PDO) and form parameter bindings.
2. Maintain the iOS Glassmorphism styling tokens and 28px squircle curvature.
3. If adjusting password security, ensure backward compatibility or migrate existing MD5 hashes grac
4. Ensure all header("location: ...") calls are immediately followed by exit().
5. Reference PROJECT_AUDIT_AND_ARCHITECTURE_SPEC.md for full database schema and route mapping.
```

End of Technical Audit Specification.